



Атрибути, ризик и периодични преглед приступа

Иста улога не значи исто право у сваком контексту

Проблем који решавамо

RBAC даје стабилну основу, али сложеније одлуке често зависе и од контекста: припадности, врсте података, времена, стања ресурса или нивоа ризика. Атрибутска правила уводе тај контекст без претварања сваке могуће комбинације у нову улогу.

ПРОБЛЕМ

Шта може поћи по злу

RBAC даје стабилну основу, али сложеније одлуке често зависе и од контекста: припадности, врсте података, времена, стања ресурса или нивоа ризика. Атрибутска правила уводе тај контекст без претварања сваке могуће комбинације у нову улогу.

ЗАШТО

Зашто је тема важна

Risk register и редован преглед приступа спречавају да се старе одлуке претворе у трајне претпоставке. Они чине видљивим преостали ризик, власништво над њим и тренутак када одлуку треба преиспитати.

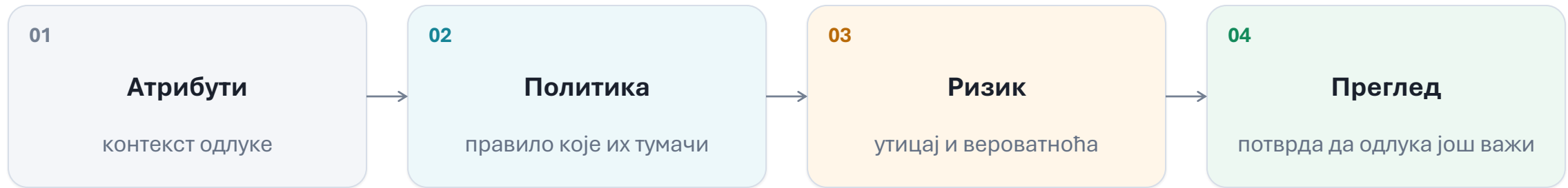
ИСХОД

Шта треба доказати

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

Четири појма граде једну одлуку

Сваки елемент одговара на друго питање и оставља другачији доказ.



КЉУЧНА ПОРУКА

Контекст даје прецизност одлуци, а редован преглед проверава да ли одлука и даље има смисла.

Атрибути

контекст одлуке

01

Атрибути се читају из поузданог, јасног контекста.

Питање: који улаз покреће ову одлуку?

02

Атрибутска одлука остаје разумљива само ако је извор сваког атрибута познат и поуздан.

Питање: која граница мора бити видљива?

03

Атрибути се прикупљају из ауторитативних извора, а не из произвољног захтева клијента.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Коју одлуку не бисте смели да заснивате само на улози и који додатни атрибут јој даје смисао?

Политика

правило које их тумачи

01

Исто стање мора довести до истог резултата политике.

Питање: који улаз покреће ову одлуку?

02

Правило треба да даје исти резултат за исти снимак контекста, како би могло да се тестира и објасни.

Питање: која граница мора бити видљива?

03

Правила треба да буду мала и састављена тако да се конфликт може објаснити.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Коју одлуку не бисте смели да заснивате само на улози и који додатни атрибут јој даје смисао?

Ризик

утицај и вероватноћа

01

Ризик укључује имовину, претњу, контролу и преосталу изложеност.

Питање: који улаз покреће ову одлуку?

02

Преглед приступа враћа тим на питање да ли право и даље има пословни разлог, чак и када је некада било правилно додељено.

Питање: која граница мора бити видљива?

03

Контекст одлуке се бележи довољно да каснији преглед разуме резултат без чувања осетљивих детаља.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Коју одлуку не бисте смели да заснивате само на улози и који додатни атрибут јој даје смисао?

Преглед

потврда да одлука још важи

01

Атрибути се прикупљају из ауторитативних извора, а не из произвољног захтева клијента.

Питање: који улаз покреће ову одлуку?

02

Правила треба да буду мала и састављена тако да се конфликт може објаснити.

Питање: која граница мора бити видљива?

03

Контекст одлуке се бележи довољно да каснији преглед разуме резултат без чувања осетљивих детаља.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Коју одлуку не бисте смели да заснивате само на улози и који додатни атрибут јој даје смисао?

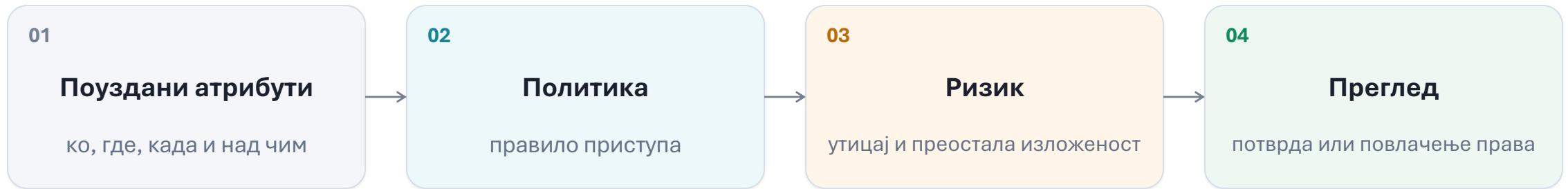
RBAC и ABAC у истој одлуци

Поређење служи да се разлике виде без тешке табеле и ситног текста.

Приступ	Снага	Ограничење
RBAC	Јасне, стабилне одговорности.	Тешко изражава време, власништво и стање.
ABAC	Користи богат контекст одлуке.	Тражи поуздане атрибуте и читљива правила.
Комбинација	Улога даје основу, атрибути прецизирају.	Потребно је пажљиво објаснити приоритет правила.
SoD	Спречава ризичне комбинације права.	Мора се проверавати кроз ефективна права.

Шема контекстуалне одлуке

Контекст даје прецизност одлуци, а редован преглед проверава да ли одлука и даље има смисла.



ЗАДАТАК

За сваки корак наведите ко га покреће, ко доноси одлуку и који траг остаје.

Од ризика до одлуке о прихватању

Од описа проблема до одлуке која може да се провери.

КОНТЕКСТ

Од ризика до одлуке о прихватању

Ризик се не уклања увек у потпуности. Неке мере би биле прескупе, неке би зауставиле важан рад, а неке зависе од спољне стране. Тада је важно да преостали ризик буде видљив, образложен и временски ограничен, а не заборављен.

01

Описати имовину, сценарио и последицу без општих формулација.

02

Навести постојеће контроле и шта оне заиста покривају.

03

Оценити шта остаје незаштићено након тих контрола.

04

Одредити власника који прихвата ризик и датум следећег прегледа.

Право приступа није заувек

Три правила која треба да остану видљива у имплементацији и ревизији.

01

**Атрибути се читају из
поузданог, јасног контекста.**

Јасно правило

02

**Исто стање мора довести до
истог резултата политике.**

Проверљива примена

03

**Ризик укључује имовину,
претњу, контролу и преосталу
изложеност.**

Видљив доказ

Како се ова тема види у развоју

Тема се види у малим одлукама током развоја, не само у завршној документацији.

РАЗВОЈНИ КОНТЕКСТ

Од принципа до радног кода

Тим издваја одлуке које не могу поштено да стану у назив једне улоге. Затим их записује као правило које се може тестирати са неколико супротних контекста. Преглед приступа проверава да ли је некадашња пословна потреба и даље стварна.

01

Именуј одлуку и њену границу.

02

Имплементирај проверу на серверу.

03

Додај позитиван и негативан доказ.

Пример: иста улога, различит тренутак

Конкретан случај показује где опште правило постаје стварна одлука система.

СЦЕНАРИО

Пример: иста улога, различит тренутак

Два оператера имају исту улогу, али један ради на инциденту који му је додељен, док други ради на другом домену. Ако политика гледа само улогу, обојица би могла да одобре исту ризичну измену. Атрибути као што су припадност домену, стање инцидента и тренутно одобрење дају одлуци контекст који назив улоге сам не може да носи.

01

Атрибутска одлука остаје разумљива само ако је извор сваког атрибута познат и поуздан.

02

Правило треба да даје исти резултат за исти снимак контекста, како би могло да се тестира и објасни.

03

Преглед приступа враћа тим на питање да ли право и даље има пословни разлог, чак и када је некада било правилно додељено.

Атрибути прецизирају стабилну основу улоге

Код почиње од исте леве ивице као наслов прозора и остаје читљив на пројектору.

```
1 public Decision CanApprove(User user, Report report, Context ctx)
2 {
3     if (!user.HasRole("operator")) return Decision.Deny("role");
4     if (report.DomainId != user.DomainId) return Decision.Deny("domain");
5     if (!ctx.ManagedDevice) return Decision.Deny("device");
6     if (!ctx.ActiveAssignment.Contains(report.Id))
7         return Decision.Deny("assignment");
8     return Decision.Allow();
9 }
```

ШТА ЈЕ ВАЖНО

Улога остаје разумљива, док домен, уређај и активни задатак одређују конкретан контекст.

ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Иста улога, супротан контекст, друга одлука

Негативан тест није споредан случај — он описује где право престаје.

```
1 [Theory]
2 [InlineData(false, "device")]
3 [InlineData(true, "assignment")]
4 public void Context_changes_the_same_roles_decision(bool managed, string reason)
5 {
6     var ctx = Context.For(managed, assigned: false);
7     var result = policy.CanApprove(user, report, ctx);
8     result.Reason.Should().Be(reason);
9 }
```

ДОКАЗ

Тестови морају показати који атрибут мења исход и који разлог систем бележи.

ПРОВЕРА

Промените једну чињеницу и очекујте јасан, стабилан разлог одбијања.

Доказ мора да одговори шта се догодило

Чува се довољно контекста за реконструкцију, али не и тајне или непотребни лични подаци.

```
1 {  
2   "riskId": "R-17",  
3   "asset": "incident-report",  
4   "owner": "operations-director",  
5   "residualRisk": "medium",  
6   "acceptedUntil": "2027-01-31",  
7   "nextReview": "2026-12-15"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Три грешке које треба препознати одмах

Свака делује практично у првој итерацији, али касније постаје скривена безбедносна граница.

01

Увођење атрибута без јасног извора и значења.

Нема јасног власника одлуке.

02

Правило које зависи од скривеног стања и даје необјашњив резултат.

Не постоји негативан сценарио.

03

Конфликт дужности откривен тек након што је штета могућа.

Доказ не показује стварни исход.

Ризик као разговор о одлуци

Добар доказ је свеж, поновљив и довољно јасан да га други члан тима протумачи.

ОБРАЗЛОЖЕЊЕ

Ризик као разговор о одлуци

Risk register није списак страшних сценарија. Он даје тиму заједнички начин да упореди утицај, вероватноћу, постојеће контроле и преосталу изложеност. Када се ризик прихвати, мора бити јасно ко га прихвата, зашто и када ће одлука бити поново прегледана.

01

Ризик повезује конкретну имовину, претњу и контролу.

02

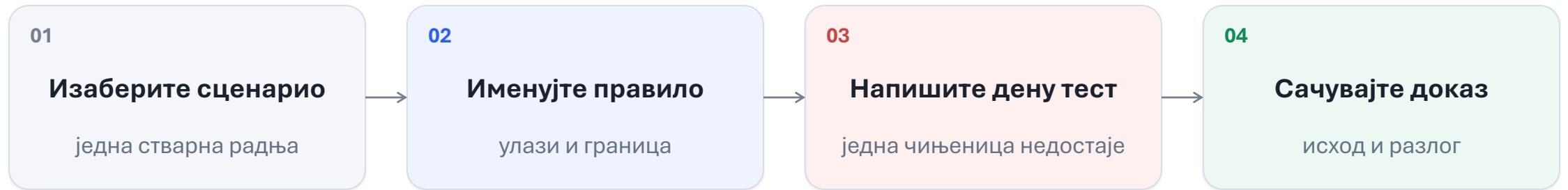
Преглед приступа и преглед ризика имају ритам, власника и очекивани исход.

03

Сегрегација дужности спречава комбинације права које би једној особи дале превелику контролу.

Мини вежба за пројекат

На једном сценарију повежите одлуку, имплементацију, негативни тест и доказ.

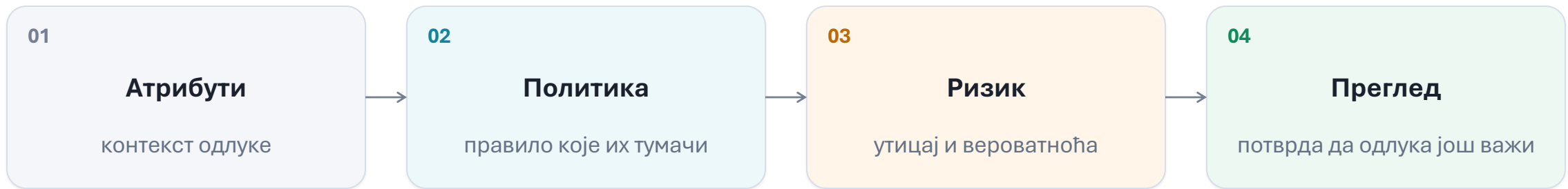


ЗАДАТАК ЗА ПРОЈЕКАТ

Примените тему „Атрибути, ризик и периодични преглед приступа“ на додељену пројектну целину и припремите доказ који други члан тима може да понови.

Провера разумевања

Тема је савладана када одлуку можете да објасните без ослањања на назив framework-a.



ЗА ЗАВРШЕТАК

Коју одлуку не бисте смели да заснивате само на улози и који додатни атрибут јој даје смисао?

Следећи корак: применити исти модел на једну реалну границу у сопственом пројекту.